

FPT University

Graduate School of Information Technology

A Cognitive Two-Tier Architecture for Automated Threat Detection and Contextual Response using Agentic AI

Capstone Project Proposal

Author: Nguyễn Đức Bình

ID: MSE13183

Supervisor: Bùi Văn Hiệu

Hanoi, 2026

Abstract

In the context of modern cybersecurity, Security Operations Centers (SOCs) face the critical “Big Data Paradox”: an overwhelming volume of events per second leads to severe alert fatigue, with a high percentage of false positives. Traditional Intrusion Detection Systems (IDS) and Security Information and Event Management (SIEM) platforms analyze data sources in isolation, significantly reducing the ability to detect sophisticated multi-stage Advanced Persistent Threats (APT). Recently, the direct application of Large Language Models (LLMs) to log analysis has been explored; however, it introduces critical vulnerabilities: excessive reasoning latency incompatible with real-time data streams, and the risk of LLM manipulation through adversarial attacks including Prompt Injection, Jailbreaks, RAG Poisoning, and Data Exfiltration.

To address these challenges, this study proposes a novel cognitive architecture that integrates a deterministic Rule Engine with a Large Language Model. By utilizing a two-tier approach, the system is designed to filter high-volume noise at wire speed (Tier 1) while reserving deep reasoning, powered by a LangGraph-based agent with Dual-RAG (MITRE ATT&CK for threat identification and NIST SP 800-61r2 for incident response), for complex and ambiguous threats (Tier 2). Furthermore, a Delimited Data Encapsulation mechanism is introduced to neutralize adversarial prompt injections without sacrificing necessary contextual payload data.

The proposed system will be implemented and evaluated on two benchmark datasets: CSE-CIC-IDS2018 for enterprise network intrusion detection and DAPT2020 for multi-stage APT tracking. Evaluation metrics will be structured using a comprehensive 5-Dimensional (5D) Evaluation Framework, encompassing Classification, Operational Metrics, Robustness, Context Quality, and Explainability.

Contents

Abstract	1
1 Introduction and Background	3
1.1 Research Problem	3
1.2 Research Objectives	3
1.3 Research Questions	4
1.4 Scope of the Study	4
1.5 Thesis Structure	4
2 Literature Review	5
2.1 Foundational Approaches	5
2.2 Related Work	5
2.2.1 Comparative Analysis of Existing Approaches	6
3 Proposed Solution and Research Methodology	7
3.1 Proposed Solution: Cognitive Two-Tier Architecture	7
3.2 Technologies and Tools	8
3.2.1 Hardware Specification	8
4 Implementation and Evaluation Plan	9
4.1 Main Development Stages	9
4.2 Evaluation Plan	9
5 Expected Results and Contributions	11
5.1 Expected Results	11
5.2 Research Contributions	11
6 Conclusion	13
References	14

1. Introduction and Background

1.1 Research Problem

Modern Security Operations Centers (SOCs) are overwhelmed by the sheer volume of security events. According to recent industry reports, the average SOC analyst processes thousands of alerts daily, with nearly half identified as false positives [10]. This phenomenon, known as *alert fatigue*, leads to critical threats being overlooked. Traditional IDS/SIEM systems exacerbate this problem by analyzing data sources (Web logs, Firewall logs, Authentication logs) in isolation, severely reducing the ability to detect sophisticated multi-stage attack chains such as Advanced Persistent Threats (APTs).

The application of Large Language Models (LLMs), particularly Agentic AI and Retrieval-Augmented Generation (RAG) architectures, to automated log analysis introduces critical operational and security vulnerabilities. First, the *reasoning latency* is prohibitively high for real-time streaming environments. Second, Agentic AI architectures drastically expand the attack surface beyond traditional LLMs. These autonomous systems are highly susceptible to a spectrum of adversarial vectors: *Indirect Prompt Injection* and *Jailbreaks* hidden within log data [2], where adversaries embed malicious instructions in dynamic fields (e.g., User-Agent) to hijack the agent’s logic. Furthermore, granting agents access to execution environments creates the risk of *Sandbox Escape* and *Remote Code Execution (RCE)*, while rendering LLM outputs on analyst dashboards introduces *Data Exfiltration* vulnerabilities via malicious Markdown rendering. Additionally, relying on external knowledge bases exposes the system to *RAG Poisoning*, where threat actors manipulate reference documents to subvert the agent’s contextual understanding. This creates a fundamental paradox: analysts must grant the agent dynamic context and execution capabilities to analyze attacks, yet doing so exposes the SOC infrastructure to hijacking.

1.2 Research Objectives

Motivated by these limitations, this study aims to develop an autonomous AI Security Agent utilizing a cognitive two-tier architecture. Instead of relying purely on a single LLM to process all logs, the thesis proposes a hybrid approach: a high-speed deterministic rule engine combined with a deep-reasoning LLM Agent. This approach is expected to drastically reduce reasoning latency by filtering noise, mitigate prompt injection via bounded encapsulation, and enhance context awareness using Long-Term Threat Memory and a Dual-RAG setup (incorporating MITRE ATT&CK for tactical threat identification and NIST SP 800-61r2 for incident response guidance). A Human-in-the-Loop (HITL) Web Dashboard will

also be developed to demonstrate practical SOC automation.

1.3 Research Questions

Based on the objectives, this thesis focuses on four core research questions: 1. Does a Two-Tier Architecture (Rule-based + LLM Agent) combined with Session-Aware Behavioral Baselineing optimize Reasoning Latency compared to a One-Tier (LLM-only) approach? 2. Can a Delimited Data Encapsulation mechanism (using Dynamic Randomized Delimiters) effectively prevent structural Prompt Injections (e.g., Delimiter Smuggling) without degrading the LLM's classification accuracy? 3. How does a Dual-RAG pipeline (combining tactical threat frameworks with incident response standards) improve the Context Relevance of the LLM's threat analysis? 4. Can an adaptive Feedback Loop with HITL Quarantine prevent Adversarial Rule Injection and safely automate defensive responses?

1.4 Scope of the Study

The research is limited to Network Intrusion Detection and SOC log triage. The in-scope components include: Data Streaming Pipeline (Redis), Tier-1 Rule Engine, LangGraph Agent with Dual-RAG, Guardrails (Volume Compression and Injection Defense), and a Streamlit HITL Dashboard with SQLite-based Threat Memory. The study does not cover fine-tuning Foundation Models, physical hardware deployment (e.g., physical Kafka clusters), or Layer 3/4 volumetric DDoS mitigation.

1.5 Thesis Structure

The thesis will be organized into six main chapters: (1) Introduction and Background; (2) Literature Review; (3) Proposed Solution and Research Methodology; (4) Implementation and Evaluation Plan; (5) Expected Results and Contributions; and (6) Conclusion.

2. Literature Review

2.1 Foundational Approaches

In the early stages of network security, Intrusion Detection Systems (IDS) primarily relied on signature-based matching (e.g., Snort, Suricata) to detect known threats. While highly efficient in terms of throughput, these systems exhibit significant limitations in identifying zero-day attacks and polymorphic malware [6].

The advent of Machine Learning (ML) led to anomaly-based IDS, where models such as Random Forests, LSTMs, and domain-specific transformers like LogBERT [3] learn a baseline of normal behavior and flag deviations. While these approaches improved zero-day detection, they remain fundamentally limited to pattern-based anomaly scoring. They cannot explain *why* a log sequence is malicious, map threats to standardized frameworks, or generate actionable remediation steps—capabilities that require the contextual reasoning of a Large Language Model.

Modern Security Information and Event Management (SIEM) systems aggregate logs, yet they still require extensive manual triage by human analysts to construct the full context of an attack.

2.2 Related Work

The recent emergence of Large Language Models (LLMs) has opened new directions for automated log summarization and incident response. Comprehensive surveys such as [4] demonstrate the growing adoption of cloud-based LLM APIs (e.g., GPT-4) for SOC automation, including log summarization and incident triage. However, relying on cloud APIs violates strict organizational data privacy policies and introduces unacceptable network latency for real-time triage.

In the realm of knowledge-augmented threat analysis, knowledge graph-based approaches to threat intelligence mapping [7] have shown promising results in automatically extracting and structuring attack techniques from CTI reports into MITRE ATT&CK-aligned graphs. Yet, existing studies generally focus solely on tactical analysis, lacking the integration of operational incident response standards (such as NIST SP 800-61r2) required for actionable SOC remediation.

Regarding adversarial robustness, the OWASP Top 10 for LLM Applications [9] and the Agent Security Bench (ASB) [13] highlight that LLM agents suffer from high attack success rates via prompt injection. While the Drain3 algorithm [5] is widely used for log template

mining, it is typically employed for storage compression rather than active injection defense. Furthermore, recent methodologies for LLM evaluation emphasize the need to address Self-Enhancement Bias by employing cross-family evaluation or statistical validation instead of isolated LLM-as-a-Judge paradigms [11, 14]. These studies reveal a critical research gap that this thesis seeks to address: the absence of a unified, self-defending architecture with rigorous, multi-dimensional evaluation.

2.2.1 Comparative Analysis of Existing Approaches

Table 1: Comparison of approaches for SOC log analysis

Approach	Local	Real-time	Anti-Injection	RAG	HITL
Signature IDS (Snort)	✓	✓	N/A	–	–
ML Anomaly IDS (RF/LSTM)	✓	✓	–	–	–
LogBERT [3]	✓	✓	–	–	–
Cloud LLM SOC [4]	–	–	–	Partial	–
SENTINEL (Ours)	✓	✓	✓	✓	✓

3. Proposed Solution and Research Methodology

3.1 Proposed Solution: Cognitive Two-Tier Architecture

The proposed solution is based on a cognitive Two-Tier Architecture designed with a strict Separation of Concerns. The core idea is to leverage the speed of deterministic rules (Tier 1) alongside the deep reasoning capabilities of an Agentic LLM (Tier 2), interconnected by robust adversarial guardrails.

At the first stage, the Tier 1 Rule Engine acts as a heuristic filter. It maintains Session-Aware Behavioral Baselines using in-memory data structures (Redis) to track request rates and known malicious IPs. This layer is designed to filter the majority of benign or purely volumetric noise at wire speed, with the exact filtration ratio to be empirically measured during evaluation. This ensures the downstream LLM is not overwhelmed by high-volume traffic.

Logs that exhibit anomalous behavior or trigger ambiguous thresholds are passed to the Guardrail Layer. Here, a two-step neutralization occurs: 1. **Template Mining (Drain3)**: Extracts the static log template to compress the token volume without altering the dynamic payload variables. 2. **Delimited Data Encapsulation**: Dynamic payload fields are wrapped within cryptographically generated randomized delimiters (e.g., <<RANDOM_HEX>>). This prevents adversaries from using Delimiter Smuggling to escape the data context and execute Prompt Injections.

Following the guardrails, the sanitized log enters Tier 2, governed by a LangGraph-based Agent. The Agent utilizes a Dual-RAG mechanism with two dedicated FAISS indexes, queried sequentially and merged before LLM inference:

- **Index 1 — MITRE ATT&CK**: Maps observed indicators to specific tactics, techniques, and procedures (TTPs), answering “*what attack is happening?*”
- **Index 2 — NIST SP 800-61r2 [1]**: Retrieves the appropriate incident response phase (Preparation, Detection, Containment, Eradication, Recovery, Lessons Learned), answering “*what should the SOC do next?*”

This fixed dual-index design eliminates the need for a routing mechanism, reducing failure points and ensuring predictable latency for evaluation. The separation bridges the gap between *tactical identification* (MITRE: what happened) and *operational response* (NIST: what to do about it).

Each index employs a **Hybrid Search** strategy combining dense semantic search (FAISS

with `all-MiniLM-L6-v2`) with sparse keyword matching (BM25Okapi), fused via **Reciprocal Rank Fusion (RRF, k=60)** [15]. This dual-signal approach maximizes both semantic understanding and exact-match recall for security-specific identifiers such as CVE IDs, IP addresses, and port numbers. Retrieved chunks undergo **Structural Sanitization**—Unicode normalization, control character removal, and length truncation—to defend against RAG Poisoning before injection into the LLM prompt.

Finally, to ensure system safety against Adversarial Rule Injection, the LLM cannot directly modify the Tier 1 firewall. Instead, its recommended rules are placed into a Quarantine state (Human-in-the-Loop Feedback Loop). A SOC manager reviews these rules via a Dashboard before they are hot-reloaded into the Tier 1 engine.

3.2 Technologies and Tools

The system is built on modern Python frameworks. The data streaming and short-term session tracking rely on Redis. The LLM reasoning engine utilizes a local quantized model (Gemma-2-9B-IT) in GGUF Q4_K_M format, served via `llama.cpp`, ensuring absolute data privacy and full offline operation.

The agentic workflow is orchestrated by LangGraph, enabling cyclical decision-making and tool-use. For knowledge retrieval, `sentence-transformers` is used alongside FAISS for dense semantic vector search and BM25Okapi (`rank\_bm25`) for sparse keyword matching. The user interface and Human-in-the-Loop dashboard are developed using Streamlit, while long-term threat memory and audit trails are persisted using SQLite.

3.2.1 Hardware Specification

To ensure full reproducibility of latency benchmarks, all experiments are conducted on the following hardware:

Component	Specification
CPU	Intel Core i7-14700KF (28 threads) @ 5.700 GHz
GPU	NVIDIA GeForce RTX 4060 Ti (16 GB VRAM)
RAM	32 GB DDR5
OS	Ubuntu 24.04.4 LTS (x86_64, Kernel 6.17)
LLM Backend	llama.cpp with GGUF Q4_K_M quantization

4. Implementation and Evaluation Plan

4.1 Main Development Stages

The implementation process will first focus on the Data Ingestion and Tier 1 Rule Engine. Two benchmark datasets are selected for evaluation:

- **CSE-CIC-IDS2018 [12]:** The de facto standard for enterprise network intrusion detection research. As of 2025, no publicly available general-purpose enterprise NIDS dataset post-2018 exists. CIC’s 2023–2026 releases (CICIoT2023, CIC-YNU-IoTMal 2026) target IoT environments and are not representative of enterprise SOC traffic. CSE-CIC-IDS2018 provides both raw PCAP and pre-extracted flow features, and its extensive adoption enables direct comparison with prior work.
- **DAPT2020 [8]:** A purpose-built dataset for multi-stage Advanced Persistent Threat detection. This complements CSE-CIC-IDS2018 by providing attack chains that exercise SENTINEL’s Tier 2 agent and Long-Term Threat Memory capabilities.

The session-tracking mechanism will be built using Redis TTLs to establish behavioral baselines.

Following this, the Guardrail Layer will be implemented, integrating the Drain3 algorithm for template mining and developing the cryptographic Delimited Data Encapsulation module to neutralize adversarial payloads.

The next critical step is the construction of the Tier 2 Agent using LangGraph and the Dual-RAG knowledge base. Two separate FAISS indexes will be populated: one with parsed MITRE ATT&CK techniques and one with NIST SP 800-61r2 incident response procedures. The agent’s prompts will be carefully engineered to strictly separate system instructions from the encapsulated payload data.

Finally, the Streamlit Dashboard and the SQLite Long-Term Threat Memory will be integrated. This phase will finalize the closed-loop process by enabling the Human-in-the-Loop feature, allowing administrators to approve dynamic rules generated by the LLM and feed them back to Tier 1.

4.2 Evaluation Plan

To validate the effectiveness of the system, the study employs a comprehensive 5-Dimensional (5D) Evaluation Framework.

To evaluate the system’s baseline accuracy, an Ablation Study will be conducted. This will compare the full Two-Tier system against a baseline LLM-only setup to observe differences in performance. The evaluation metrics will include:

- **1. Classification:** F1-Score, Precision, Recall, and False Positive Rate (FPR), evaluated using McNemar’s Test ($p < 0.05$) for statistical significance.
- **2. Operational:** Processing Latency (serving as a proxy for Mean Time To Detect/Respond), HITL Escalation Rate, and RAG Semantic Cache Hit Rate, evaluated using the Mann-Whitney U Test ($p < 0.05$).
- **3. Robustness:** The Guardrail Defeat Rate will be tested against 45 curated adversarial samples covering Structural Attacks (Delimiter Smuggling) and Semantic Confusion.
- **4. Context Quality:** To evaluate the LLM’s reasoning and mitigate Self-Enhancement Bias, a cross-family LLM-as-a-Judge methodology will be employed: while Gemma-2-9B-IT serves as the primary reasoning model, **Llama-3.1-8B-Instruct** (a different model family) will serve as the judge, assessing Context Precision, Answer Relevancy, Faithfulness, and Context Recall using the RAGAS framework [11]. Judge scores will be cross-validated with automated RAGAS metrics for statistical consistency.
- **5. Explainability:** Audit Trail Completeness Rate will be measured deterministically via programmatic field presence checks.

5. Expected Results and Contributions

5.1 Expected Results

This study is expected to develop a complete, autonomous pipeline capable of performing the full sequence of SOC tasks—log ingestion, heuristic filtering, adversarial sanitization, deep reasoning, and rule generation. The quantitative targets for the 5D Evaluation Framework are as follows:

Table 2: Quantitative performance targets

Dimension	Target	Basis
F1-Score (Classification)	≥ 0.90	IDS benchmark standards [6]
Latency Reduction vs LLM-only	$\geq 60\%$	Tier 1 filters majority of traffic
Guardrail Defeat Rate	$< 10\%$	45 curated adversarial samples
Context Relevance (RAGAS)	≥ 0.85	Dual-RAG with MITRE + NIST
Audit Trail Completeness	100%	Deterministic field-presence check

The integration of Delimited Data Encapsulation is expected to achieve a Guardrail Defeat Rate below 10% against structural prompt injection attacks, demonstrating a robust defense mechanism without stripping away the necessary payload forensics required by the LLM.

Furthermore, the Dual-RAG integration is expected to yield Context Relevance scores of 0.85 or higher, ensuring that the Agent generates actionable, incident-response-aligned remediation steps grounded in NIST SP 800-61r2 rather than hallucinated responses.

5.2 Research Contributions

From an academic standpoint, the primary contribution of this research is the proposal of a novel Cognitive Two-Tier Architecture that securely bridges deterministic rule engines with Agentic LLMs. This approach remains underexplored in cybersecurity literature, particularly concerning the deployment of local, privacy-preserving LLMs equipped with dynamic adversarial guardrails.

The second contribution lies in the methodological framework for evaluating LLM-based SOC agents. By introducing the 5-Dimensional (5D) Evaluation Framework—combining statistical classification tests, operational metrics, adversarial robustness, cross-family LLM-as-a-Judge context quality, and explainability assessments—this study provides a comprehensive baseline for future research in AI-driven cybersecurity.

Finally, the practical contribution is the establishment of a standardized, open-source pipeline

(SENTINEL) that integrates all stages of alert triage and Human-in-the-Loop remediation. This serves as a scalable, real-world framework that organizations can adapt to alleviate SOC alert fatigue safely.

6. Conclusion

In this study, we propose a Cognitive Two-Tier Architecture that combines a high-speed deterministic Rule Engine with a deep-reasoning Agentic Large Language Model. This architecture is designed to address the “Big Data Paradox” and alert fatigue currently plaguing modern Security Operations Centers, while simultaneously mitigating the inherent vulnerabilities of applying LLMs directly to adversarial log data.

The system leverages the speed of Tier 1 to filter massive volumes of noise and relies on robust Guardrails—specifically Delimited Data Encapsulation—to neutralize prompt injections before they reach the Tier 2 Agent. Supported by a Dual-RAG knowledge base consisting of MITRE ATT&CK for tactical threat identification and NIST SP 800-61r2 for incident response guidance, the Agent can provide highly contextualized, accurate threat assessments with actionable remediation steps. Finally, the closed-loop design ensures safety through a Human-in-the-Loop Quarantine system.

The expected contributions of this research include proposing a novel hybrid architecture, providing empirical evaluation methodologies for AI Security Agents, and developing a practical, scalable pipeline for real-time automated incident response. Future research may extend the Dual-RAG pipeline with Sigma Rules for automated rule synthesis and MITRE D3FEND for countermeasure-aware response generation.

References

- [1] P. Cichonski, T. Millar, T. Grance, and K. Scarfone, “Computer Security Incident Handling Guide,” *NIST Special Publication 800-61 Revision 2*, 2012.
- [2] K. Greshake, S. Abdelnabi, S. Mishra, A. Endres, T. Holz, and M. Fritz, “More than you’ve asked for: A Comprehensive Analysis of Novel Prompt Injection Threats to Application-Integrated Large Language Models,” *arXiv preprint arXiv:2302.12173*, 2023.
- [3] H. Guo, S. Yuan, and X. Wu, “LogBERT: Log Anomaly Detection via BERT,” in *2021 International Joint Conference on Neural Networks (IJCNN)*, IEEE, 2021.
- [4] M. Habibzadeh *et al.*, “Large Language Models for Security Operations Centers: A Comprehensive Survey,” *arXiv preprint*, 2025.
- [5] P. He, J. Zhu, Z. Zheng, and M. R. Lyu, “Drain: An Online Log Parsing Approach with Fixed Depth Tree,” in *2017 IEEE International Conference on Web Services (ICWS)*, 2017.
- [6] A. Khraisat, I. Gondal, P. Vamplew, and J. Kamruzzaman, “Survey of intrusion detection systems: techniques, datasets and challenges,” *Cybersecurity*, vol. 2, no. 1, p. 20, 2019.
- [7] Z. Li, J. Ning, and B. Wang, “AttackKG: Constructing Technique Knowledge Graph from Cyber Threat Intelligence Reports,” in *Findings of EACL 2023*, arXiv:2111.07093.
- [8] S. Myneni, A. Chowdhary, A. Sabur, D. Dasgupta *et al.*, “DAPT 2020 — Constructing a Benchmark Dataset for Advanced Persistent Threats,” in *Workshop on Deployable Machine Learning for Security Defense (MLHat)*, KDD 2020, 2020.
- [9] OWASP Foundation, “OWASP Top 10 for Large Language Model Applications,” OWASP, 2025.
- [10] Ponemon Institute, “The State of Security Operations: Alert Fatigue and Analyst Burnout,” *Annual Cybersecurity Report*, 2023.
- [11] S. Shahul Es *et al.*, “RAGAS: Automated Evaluation of Retrieval Augmented Generation,” *arXiv preprint arXiv:2309.15217*, 2023.
- [12] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, “Toward Generating a New Intrusion Detection Dataset and Intrusion Traffic Characterization,” in *4th International Conference on Information Systems Security and Privacy (ICISSP)*, 2018.

- [13] Y. Zhang *et al.*, “Agent Security Bench (ASB): Evaluating the Robustness of LLM Agents,” *arXiv preprint arXiv:2410.02644*, 2024.
- [14] L. Zheng *et al.*, “Judging LLM-as-a-Judge with MT-Bench and Chatbot Arena,” in *Proceedings of NeurIPS 2023*, 2023.
- [15] G. V. Cormack, C. L. A. Clarke, and S. Buettcher, “Reciprocal Rank Fusion outperforms Condorcet and individual Rank Learning Methods,” in *Proceedings of the 32nd International ACM SIGIR Conference on Research and Development in Information Retrieval*, 2009, pp. 758–759.